CloudSentry

Pricing Opportunities & Why Customers Buy

A multi-cloud security posture & Infrastructure-as-Code platform (AWS · GCP · Terraform)

The one-line thesis: customers do not pay for a scanner — the scanners are free and open source. They pay to **pass audits**, to **avoid breaches with always-on coverage**, and to **save their security team's time**. Revenue comes from a recurring subscription priced per connected cloud account, tiered so that the features budget-holders need — compliance reporting, continuous monitoring, SSO/RBAC — sit in the paid tiers.

1. Why Would Customers Actually Pay? (Concrete Reasoning)

Every paying customer is solving a business problem, not a technical one. The free CLI tools (Prowler, Checkov) prove the *capability* exists; what follows is why people still open their wallets:

Reason 1 — Compliance is a budget line, not a nice-to-have

A startup cannot close enterprise deals without SOC 2; a payments company is legally bound by PCI-DSS; a health company needs HIPAA. These require **continuous** monitoring and **auditor-ready evidence**, not a one-off scan a developer ran last quarter. A failed audit blocks revenue and contracts. Companies already budget for this — the only question is who they hand the money to.

> *"We pay $X/month so that when the auditor asks, we export one report instead of three engineers spending two weeks."*

Reason 2 — The free tools do not scale to a real org

Prowler and Checkov are brilliant *CLIs*. But a company with 40 AWS accounts and 6 teams cannot run CLIs by hand, store JSON in a folder, and call that a security program. They need multi-account aggregation, history/drift ("what is *new* since last week?"), ownership routing, and a dashboard execs can read. That operational layer is the product — and it is pure labour the customer would otherwise pay a salaried engineer to build badly.

Reason 3 — Breaches are catastrophically expensive; prevention is cheap by comparison

A single public S3 bucket or open database port can mean a breach, regulatory fines, and reputational loss costing millions. Against that, a few thousand dollars a month for continuous detection is trivially justified — it is insurance with a measurable payoff. Security buyers think in **risk reduced per dollar**, and this ratio is extremely favourable.

Reason 4 — Build-vs-buy almost always favours buy

A company *could* wire Prowler + Checkov into their own pipeline. But that means engineer salaries, ongoing maintenance, and a half-finished internal tool nobody owns. Buying a supported product with SLAs, integrations, and compliance packs is cheaper and faster than an engineer's loaded cost — and it is someone else's problem to keep current.

Reason 5 — It plugs into money-making and deal-closing moments

Auto-created Jira tickets, Slack alerts, and a clean compliance PDF to hand a prospect's security team directly accelerate *their* revenue. A tool that helps close deals and ship faster is funded from a very different (larger) budget than a "dev utility."

Summary of buying triggers:

- **Trigger event:** an upcoming SOC 2 / ISO / PCI audit, a new enterprise customer demanding proof, or a near-miss incident.
- **Economic buyer:** CISO / Head of Security / Compliance — budget holders, not individual developers.

- **Value metric:** risk reduced and audit hours saved, both of which dwarf the subscription price.

2. Pricing Opportunities — The Tier Ladder

Land small, expand by feature and account count. Each tier maps to a buyer and the problem they are paying to solve:

Tier	Target buyer	What's included	Indicative price
Free / OSS	Individual dev, evaluator	CloudSentry CLI, single-account scan, JSON/SARIF output	$0 (funnel & trust)
Starter	Small team / startup	Hosted dashboard, up to ~3 accounts, scheduled scans, email alerts	~$100–300 / mo
Pro	Growing eng org	Multi-account, trend/drift history, Slack + Jira, multiple users	~$1,000–3,000 / mo
Enterprise	CISO / regulated co.	Compliance packs (SOC2/PCI/HIPAA), SSO/SAML, RBAC, auto-remediation, API, SLA	$30k–$250k+ / yr

Prices are industry-calibrated ballparks for positioning, not quotes. The lever is usually **per connected cloud account per month**, with tiers bundling N accounts plus overage.

Pricing levers you can pull

Lever	How it's charged	Best for
Per cloud account	$X per AWS account / GCP project / month	Default; easy to understand
Per resource	Priced on # of resources scanned	Aligns price to value
Per seat	Per dashboard user	Secondary, layered on top
Usage add-ons	Per on-demand deep scan / report export	Expansion revenue
Services	Fixed-fee audits, custom policies, onboarding	Fast near-term cash

3. How the Revenue Reaches You

- **Recurring SaaS subscription** (the core, ~90% of revenue) — monthly/annual, billed via Stripe for self-serve and PO/invoice for enterprise.
- **Tiered feature gating** — compliance reports and SSO live in Enterprise because that is exactly what budget-holders need; they pay 5–10× the Pro price for them.
- **Cloud marketplaces** (AWS / GCP Marketplace) — customers buy through their existing cloud bill; shortens procurement dramatically (marketplace takes ~3%).
- **Professional services / MSSP** — audits and managed triage as retainers; high margin and the fastest path to first revenue for a small team.

Margin note

The cloud APIs you consume to scan are **free** — you pay only for your own compute (bursty scan workers that scale to zero), a database, and storage. Gross margins of **70–85%** are normal once customers are onboarded; the real cost at scale is the sales and support humans, not infrastructure.

4. Illustrative Revenue Snapshot

A deliberately modest, achievable mix — showing you do *not* need to beat Wiz to build a real business. Annual Recurring Revenue (ARR) from a handful of customers:

Tier	Customers	Avg price	Annual revenue
Starter	20	$200 / mo	$48,000
Pro	10	$2,000 / mo	$240,000
Enterprise	3	$60,000 / yr	$180,000
Total ARR	**33**	—	**$468,000**

Illustrative only. At ~75% gross margin this is a solid six-figure business from just 33 customers — reachable by a focused solo/small team, especially starting from a services motion.

5. Recommended Path (Small / Solo Founder)

- **Services first** — sell cloud-security audits / compliance-prep using Prowler + Checkov + CloudSentry as your delivery engine. Revenue in weeks; teaches you what customers truly pay for.
- **Productize the repetition** — turn the dashboard and compliance reports you build by hand into the SaaS.
- **Pick a niche** — e.g. “SOC 2 for GCP-native startups.” A focused tool beats a broad one when competing against giants.
- **Free OSS as the funnel** — CloudSentry CLI drives adoption → paid SaaS for teams → Enterprise for compliance/SSO.

CloudSentry — prepared as a planning aid. Figures are industry-calibrated estimates for positioning and modelling, not financial advice or quotes.